

Project 6 — Message Integrity & Replay Protection Test Report

Project: Hydroficient IoT Cyber Defense Externship

System: Grand Marina Hotel Water Monitoring System

Security Control: Message Integrity & Replay Protection

Author: Christine M. Khayat

Date: September 26, 2026

1. Objective

The objective of this project was to identify and address a message replay vulnerability in the Grand Marina Hotel's MQTT-based water monitoring system.

The initial mTLS implementation successfully protected communication and verified device identity, but it did not verify whether an incoming message was new or had already been received.

This project implemented and tested three additional message-level security controls:

1. **HMAC-SHA256** — verifies message integrity and detects tampering.
2. **Timestamp validation** — rejects messages older than 30 seconds.
3. **Sequence counter** — detects previously processed or replayed messages.

The objective of the experiments was to verify that legitimate messages are accepted while replayed messages are rejected.

2. Test Environment

MQTT Security

- MQTT broker: Mosquitto
- MQTT security: Mutual TLS (mTLS)

- MQTT port: 8883
- Client certificate authentication: Enabled
- Topic:
hydroficient/grandmarina/device-001/sensors

Device

- Device ID: HYDROLOGIC-Device-001
- Certificate: certs/device-001.pem

Replay Protection

- HMAC algorithm: HMAC-SHA256
 - Timestamp window: 30 seconds
 - Sequence tracking: Enabled
 - Replay testing tool: replay_attacker.py
-

3. Part 1 — Defended Pipeline Test

3.1 Publisher Test

The defended publisher was started using:

```
cd "/Users/christinekh/Documents/loT Hydroficient-Extern/Week6/Hydroficient-project"  
python3 publisher_defended.py
```

The publisher successfully connected to the MQTT broker using the device certificate.

It generated five messages containing:

- Sensor readings
- UTC timestamps
- Sequence numbers
- HMAC-SHA256 signatures

Publisher Results

Message	Flow Rate	Sequence	HMAC
---------	-----------	----------	------

1	54.61 LPM	1	ed891e90ebfc...
2	52.94 LPM	2	fbc163a3f916...
3	50.20 LPM	3	9273f2f7f29d...
4	49.60 LPM	4	dc259253f5f2...
5	47.01 LPM	5	3a06cd06f208...

Result: 5/5 messages were successfully published.

Screenshot 1 — Defended Publisher

```

[SUCCESS] Connected to broker as GrandMarina-Dashboard-Defended
[INFO] Replay defenses ACTIVE
[INFO] HMAC verification: ON
[INFO] Timestamp window: 30 seconds
[INFO] Sequence tracking: ON
[INFO] Subscribing to: hydroficient/grandmarina/#
[SUBSCRIBED] QoS granted: (1,)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 54.61 LPM | Seq: 1
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 1 accepted, 0 rejected (1 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 52.94 LPM | Seq: 2
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 2 accepted, 0 rejected (2 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 50.2 LPM | Seq: 3
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 3 accepted, 0 rejected (3 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 49.6 LPM | Seq: 4
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 4 accepted, 0 rejected (4 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 47.0 LPM | Seq: 5
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 5 accepted, 0 rejected (5 total)

=====
HYDROLOGIC Sensor Publisher (Defended)
=====
Device ID: 001
Topic: hydroficient/grandmarina/device-001/sensors
Certificate: certs/device-001.pem
Defenses: timestamp + sequence counter + HMAC-SHA256
=====
/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project/
publisher_defended.py:168: DeprecationWarning: Callback API version 1 is depreca
ted, update to latest version
  client = mqtt.Client(client_id=CLIENT_NAME, **MQTT_CLIENT_ARGS)

[CONNECTING] localhost:8883...
[SUCCESS] Connected to broker as HYDROLOGIC-Device-001
[INFO] Replay defenses ACTIVE: timestamp + sequence + HMAC

[PUBLISHING] Sending defended readings (Ctrl+C to stop)...

[1] Published: 54.61 LPM | seq=1 | hmac=ed891e90ebfc...
[2] Published: 52.94 LPM | seq=2 | hmac=fbc163a3f916...
[3] Published: 50.2 LPM | seq=3 | hmac=9273f2f7f29d...
[4] Published: 49.6 LPM | seq=4 | hmac=dc259253f5f2...
[5] Published: 47.01 LPM | seq=5 | hmac=3a06cd06f208...

```

Caption: Defended publisher successfully connects using mTLS and publishes messages containing sequence numbers and HMAC-SHA256 signatures.

3.2 Subscriber Validation

The defended subscriber received all five legitimate messages.

For every message:

- HMAC verification: **PASS**
- Timestamp validation: **PASS**
- Sequence validation: **PASS**
- Message status: **ACCEPTED**

Subscriber Results

Message	HMA C	Timestamp	Sequence	Result
1	PASS	PASS	PASS	ACCEPTED
2	PASS	PASS	PASS	ACCEPTED
3	PASS	PASS	PASS	ACCEPTED
4	PASS	PASS	PASS	ACCEPTED
5	PASS	PASS	PASS	ACCEPTED

Final statistics:

- Accepted: **5**
- Rejected: **0**
- Total: **5**

Screenshot 2 — Successful Validation

```
Last login: Sat Sep 26 07:28:46 on console
christinekh@christinekhshMBP ~ % cd "/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project"
christinekh@christinekhshMBP Hydroficient-project % python3 subscriber_defended.py
=====
Grand Marina Security Dashboard (Defended)
=====
Subscribing to: hydroficient/grandmarina/#
Certificate: certs/device-001.pem
Max message age: 30 seconds
=====
/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project/subscriber_defended.py:265: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
client = mqtt.Client(client_id=CLIENT_NAME, **MQTT_CLIENT_ARGS)

[CONNECTING] localhost:8883...

[LISTENING] Waiting for messages (Ctrl+C to stop)...

[SUCCESS] Connected to broker as GrandMarina-Dashboard-Defended
[INFO] Replay defenses ACTIVE
[INFO] HMAC verification: ON
[INFO] Timestamp window: 30 seconds
[INFO] Sequence tracking: ON
[INFO] Subscribing to: hydroficient/grandmarina/#
[SUBSCRIBED] QoS granted: (1,)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 54.61 LPM | Seq: 1
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 1 accepted, 0 rejected (1 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 52.94 LPM | Seq: 2
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 2 accepted, 0 rejected (2 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 50.2 LPM | Seq: 3
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 3 accepted, 0 rejected (3 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 49.6 LPM | Seq: 4
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 4 accepted, 0 rejected (4 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 47.01 LPM | Seq: 5
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 5 accepted, 0 rejected (5 total)
```

Caption: Subscriber accepts legitimate messages after successfully passing HMAC, timestamp, and sequence validation.

4. Part 2 — Replay Attack After More Than 30 Seconds

4.1 Capturing Legitimate Messages

The replay attack tool was used to capture five legitimate messages:

```
python3 replay_attacker.py --mode capture --count 5
```

The tool successfully captured and saved five messages to:

```
captured_messages.json
```

Captured Messages

Message	Device	Flow Rate
1	HYDROLOGIC-Device-001	47.18 LPM
2	HYDROLOGIC-Device-001	54.25 LPM
3	HYDROLOGIC-Device-001	52.39 LPM
4	HYDROLOGIC-Device-001	54.48 LPM
5	HYDROLOGIC-Device-001	54.22 LPM

Result: 5/5 messages were successfully captured.

4.2 Replaying the Captured Messages

The captured messages were replayed using:

```
python3 replay_attacker.py --mode replay
```

The replay tool successfully sent all five captured messages back to the MQTT broker.

The messages contained their original sequence numbers and timestamps.

4.3 Subscriber Response

The subscriber rejected all five replayed messages.

The sequence counter detected that each sequence number had already been processed.

Example:

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 47.18 LPM | Seq: 1

Failed check: SEQUENCE

Reason: Sequence 1 <= last seen 5 (replay detected)

The same behavior occurred for sequences 2–5.

Results

Replay	Sequence	Result
1	1	REJECTED
2	2	REJECTED
3	3	REJECTED
4	4	REJECTED
5	5	REJECTED

Statistics after the first replay attempt:

- Accepted: **5**
- Rejected: **5**
- Total processed: **10**

The replay was successfully detected by the sequence counter.

Screenshot 5 — Sequence Replay Detection

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 47.18 LPM | Seq: 1
Failed check: SEQUENCE
Reason: Sequence 1 <= last seen 5 (replay detected)
Stats: 5 accepted, 1 rejected (6 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.25 LPM | Seq: 2
Failed check: SEQUENCE
Reason: Sequence 2 <= last seen 5 (replay detected)
Stats: 5 accepted, 2 rejected (7 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 52.39 LPM | Seq: 3
Failed check: SEQUENCE
Reason: Sequence 3 <= last seen 5 (replay detected)
Stats: 5 accepted, 3 rejected (8 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.48 LPM | Seq: 4
Failed check: SEQUENCE
Reason: Sequence 4 <= last seen 5 (replay detected)
Stats: 5 accepted, 4 rejected (9 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.22 LPM | Seq: 5
Failed check: SEQUENCE
Reason: Sequence 5 <= last seen 5 (replay detected)
Stats: 5 accepted, 5 rejected (10 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 47.18 LPM | Seq: 1
Failed check: TIMESTAMP
Reason: Age: 95.0s (max: 30s)
Stats: 5 accepted, 6 rejected (11 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.25 LPM | Seq: 2
Failed check: TIMESTAMP
Reason: Age: 91.0s (max: 30s)
Stats: 5 accepted, 7 rejected (12 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 52.39 LPM | Seq: 3
Failed check: TIMESTAMP
Reason: Age: 87.0s (max: 30s)
Stats: 5 accepted, 8 rejected (13 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.48 LPM | Seq: 4
Failed check: TIMESTAMP
Reason: Age: 83.0s (max: 30s)
Stats: 5 accepted, 9 rejected (14 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 54.22 LPM | Seq: 5
Failed check: TIMESTAMP
Reason: Age: 79.0s (max: 30s)
Stats: 5 accepted, 10 rejected (15 total)

Caption: Subscriber rejects previously processed messages because their sequence numbers are less than or equal to the last accepted sequence number.

4.4 Timestamp Protection

The same captured messages were replayed again after additional time had passed.

The subscriber rejected the messages because they exceeded the configured 30-second timestamp window.

Examples from the test:

- Sequence 1: **95.0 seconds old**
- Sequence 2: **91.0 seconds old**
- Sequence 3: **87.0 seconds old**
- Sequence 4: **83.0 seconds old**
- Sequence 5: **79.0 seconds old**

The subscriber reported:

Failed check: **TIMESTAMP**

Reason: Age: 95.0s (max: 30s)

Results

Replay	Message Age	Timestamp Limit	Result
1	95.0 s	30 s	REJECTED
2	91.0 s	30 s	REJECTED
3	87.0 s	30 s	REJECTED
4	83.0 s	30 s	REJECTED
5	79.0 s	30 s	REJECTED

Result: Timestamp validation successfully rejected stale messages.

5. Part 3 — Replay Within 10 Seconds

This experiment tested an important limitation of timestamp-based protection.

A replay performed shortly after the original message may still have a valid timestamp. Therefore, timestamp validation alone may not detect the attack.

The subscriber was restarted to reset its sequence counter.

Three legitimate messages were then published and captured:

Message	Flow Rate	Sequence
1	52.64 LPM	1
2	46.50 LPM	2
3	48.77 LPM	3

The messages were replayed only a few seconds after they were originally captured.

Replay Timing

Message	Original Time	Replay Time
1	11:54:11	11:54:26
2	11:54:16	11:54:27
3	11:54:21	11:54:28

Because the replay occurred within the 30-second timestamp window, the timestamp check was still valid.

However, the sequence counter rejected all three messages.

Example:

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 52.64 LPM | Seq: 1

Failed check: SEQUENCE

Reason: Sequence 1 <= last seen 3 (replay detected)

Results

Scenario	HMAC	Timestamp	Sequence	Result
Fresh message	PASS	PASS	PASS	ACCEPTED
Replay after 30+ sec	PASS	FAIL	FAIL	REJECTED
Replay within ~10 sec	PASS	PASS	FAIL	REJECTED

Screenshot 7 — Fresh Replay Rejection

```
Last login: Sat Sep 26 14:51:53 on ttys000
christinekh@christinekhMBP ~ % cd "/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project"
christinekh@christinekhMBP Hydroficient-project % python3 replay_attacker.py --mode capture --count 3
=====
REPLAY ATTACK TOOL - Capture Mode
=====
Target: 3 messages
Output: captured_messages.json
=====
/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project/replay_attacker.py:114: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
client = mqtt.Client(client_id="replay-attacker-capture", **MQTT_CLIENT_ARGS)

[CONNECTING] localhost:8883...
[LISTENING] Waiting for messages to capture...

[CONNECTED] Listening on: hydroficient/grandmarina/#
[CAPTURED 1/3] HYDROLOGIC-Device-001 - 52.64 LPM
[CAPTURED 2/3] HYDROLOGIC-Device-001 - 46.5 LPM
[CAPTURED 3/3] HYDROLOGIC-Device-001 - 48.77 LPM

[DONE] Captured 3 messages
[SAVED] captured_messages.json
[SAVED] 3 messages saved to captured_messages.json
christinekh@christinekhMBP Hydroficient-project % python3 replay_attacker.py --mode replay
=====
REPLAY ATTACK TOOL - Replay Mode
=====
Loaded 3 captured messages
=====
/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project/replay_attacker.py:175: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
client = mqtt.Client(client_id="replay-attacker", **MQTT_CLIENT_ARGS)

[CONNECTING] localhost:8883...

[REPLAYING] Sending captured messages...

[REPLAYING 1/3] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-26T11:54:11.43667Z
Replayed at: 2026-09-26T11:54:26.861470Z

[REPLAYING 2/3] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-26T11:54:16.443383Z
Replayed at: 2026-09-26T11:54:27.863834Z

[REPLAYING 3/3] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-26T11:54:21.443758Z
Replayed at: 2026-09-26T11:54:28.869140Z

[DONE] Replayed 3 messages
[NOTE] Check your subscriber - did it accept them all?
christinekh@christinekhMBP Hydroficient-project % █

Last login: Sat Sep 26 14:31:51 on ttys003
christinekh@christinekhMBP ~ % cd "/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project"
christinekh@christinekhMBP Hydroficient-project % python3 subscriber_defended.py
=====
Grand Marina Security Dashboard (Defended)
=====
Subscribing to: hydroficient/grandmarina/#
Certificate: certs/device-001.pem
Max message age: 30 seconds
=====
/Users/christinekh/Documents/IoT Hydroficient-Extern/Week6/Hydroficient-project/subscriber_defended.py:265: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
client = mqtt.Client(client_id=CLIENT_NAME, **MQTT_CLIENT_ARGS)

[CONNECTING] localhost:8883...

[LISTENING] Waiting for messages (Ctrl+C to stop)...

[SUCCESS] Connected to broker as GrandMarina-Dashboard-Defended
[INFO] Replay defenses ACTIVE
[INFO] HMAC verification: ON
[INFO] Timestamp window: 30 seconds
[INFO] Sequence tracking: ON
[INFO] Subscribing to: hydroficient/grandmarina/#
[SUBSCRIBED] QoS granted: (1,)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 52.64 LPM | Seq: 1
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 1 accepted, 0 rejected (1 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 46.5 LPM | Seq: 2
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 2 accepted, 0 rejected (2 total)

[ACCEPTED] Device: HYDROLOGIC-Device-001 | Flow: 48.77 LPM | Seq: 3
HMAC: PASS | Timestamp: PASS (Age: 0.0s (max: 30s)) | Sequence: PASS
Stats: 3 accepted, 0 rejected (3 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 52.64 LPM | Seq: 1
Failed check: SEQUENCE
Reason: Sequence 1 <= last seen 3 (replay detected)
Stats: 3 accepted, 1 rejected (4 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 46.5 LPM | Seq: 2
Failed check: SEQUENCE
Reason: Sequence 2 <= last seen 3 (replay detected)
Stats: 3 accepted, 2 rejected (5 total)

[REJECTED] Device: HYDROLOGIC-Device-001 | Flow: 48.77 LPM | Seq: 3
Failed check: SEQUENCE
Reason: Sequence 3 <= last seen 3 (replay detected)
Stats: 3 accepted, 3 rejected (6 total)
█
```

Caption: A replay performed within the timestamp window is rejected by sequence tracking even though the timestamp remains valid.

6. Defense Comparison

The experiments demonstrated that each security mechanism protects against a different type of message-level attack.

Defense	Protects Against	Limitation
HMAC-SHA256	Message modification and tampering	Does not prevent exact replay of a valid message
Timestamp validation	Old/stale messages	Cannot reliably detect a very recent replay within the allowed window
Sequence counter	Previously processed/replayed messages	Requires persistent state and correct counter management

The controls therefore provide **layered protection** rather than relying on a single mechanism.

7. Final Results

The complete testing demonstrated that the defended MQTT pipeline can:

- Verify message integrity using HMAC-SHA256.
- Reject messages with invalid or modified authentication data.
- Reject messages that are older than the configured 30-second window.
- Detect previously processed sequence numbers.
- Reject replay attacks even when the replay occurs within the timestamp window.
- Accept legitimate messages when all security checks pass.

Overall Test Summary

Test	Expected Result	Actual Result	Status
Legitimate defended messages	Accepted	5/5 accepted	PASS
Replay after 30+ seconds	Rejected	Rejected	PASS

Replay within ~10 seconds	Rejected	Rejected	PASS
Sequence replay detection	Detect replay	Detected	PASS
Timestamp protection	Reject stale messages	Rejected	PASS

8. Security Conclusion

The testing confirmed that the original mTLS-secured MQTT pipeline had a message freshness gap: although device identity and communication confidentiality were protected, previously valid messages could initially be replayed without detection.

The addition of HMAC-SHA256, timestamp validation, and sequence tracking addressed this gap through multiple layers of message-level protection.

The experiments demonstrated that:

HMAC provides message integrity, timestamp validation provides freshness, and sequence tracking provides replay detection.

The combination provides stronger protection than any single mechanism alone and makes replay attacks detectable by the Grand Marina water monitoring system.

9. Evidence Collected

The following evidence was collected during testing:

- Defended publisher output
- Defended subscriber output
- Five captured MQTT messages
- `captured_messages.json`
- Replay attack output
- Sequence-based replay rejection
- Timestamp-based replay rejection
- Fresh replay rejection within the timestamp window
- Defense comparison results

These results can be used as supporting evidence for the security assessment and for demonstrating the effectiveness of the implemented message integrity and replay protection controls.

10. Final Recommendation

The Grand Marina water monitoring system should retain the layered message protection implemented during this project.

For a production deployment:

1. Keep mTLS enabled for device authentication and encrypted communication.
2. Use HMAC-SHA256 or an equivalent message authentication mechanism.
3. Enforce timestamp freshness limits.
4. Maintain per-device sequence counters.
5. Persist sequence state securely so counters cannot be reset by restarting a device or subscriber.
6. Store cryptographic secrets securely rather than directly in source code.
7. Log and monitor rejected messages as potential security events.
8. Periodically test replay and message-tampering protections.

Final assessment: The tested replay attacks were successfully detected and rejected by the implemented layered defenses.